

purdue-safety-systems brief

Purdue Safety Instrumented Systems (parallel to L1) — Cross-Vendor Threat & Detection Brief

Scope: The kill-switch layer — Safety Instrumented Systems (SIS) controllers, SIS engineering workstations, and safety field instruments. Often labeled Level 0.5 (instruments) and Level 1.5 (logic solvers) to distinguish them from the Basic Process Control System (BPCS) at L1. Source material is drawn from four per-vendor briefs: [Schneider brief Group C](#) (Triconex Tricon/Trident/Tri-GP — the TRITON case study and CVE-2018-8872), [Honeywell brief Group E](#) (Safety Manager FSC and the ICEFALL CVE-2022-30313/14/15 cluster), [Siemens brief Group A/D](#) (STEP7 Safety on TIA Portal V21 and S7-1500F/T-F controllers), and [Rockwell brief Group A/B](#) (GuardLogix 5580 and Compact GuardLogix 5380 safety variants). No SIS controller firmware has been carved or hashed in this repository's `firmware-staging\` trees — the entire layer is **research-only** at the time of writing. Engineering-tool media (TIA Portal V21 / STEP7 Safety on DVD1, ~686K hashes) is the one extracted exception.

Architecture grouping (organized by ROLE within this layer, not by vendor)

Class (role)	Products (cross-vendor)	Stack	Catalog depth
A. Triple/Quad-Redundant SIS Logic Solver (L1.5)	Schneider Triconex Tricon v10/v11, Trident, Tri-GP; Honeywell Safety Manager FSC R145.1–R152.2, FSC10/20, QPP quad-CPU	Proprietary safety RTOS on triple/quad-redundant MP/IOP modules; TriStation UDP/1502 (Schneider) and FSC-SafeNet UDP/51966 (Honeywell); mandatory PROGRAM/RUN/REMOTE key-switch	research only — see schneider brief Group C , honeywell brief Group E
B. Integrated Safety PLC (L1.5, BPCS-converged chassis)	Rockwell GuardLogix 5580 (1756-L8xS), Compact GuardLogix 5380; Siemens S7-1500F + S7-1500T-F with STEP7 Safety / Distributed Safety / Safety Matrix	VxWorks 6.x/7.x or ADONIS RTOS, CIP Safety over EtherNet/IP (Rockwell) or PROFIsafe over PROFINET (Siemens), safety-task partition on a standard control CPU	research only — see rockwell brief Group A/B , siemens brief Group D
C. SIS Engineering Workstation	Schneider TriStation 1131; Honeywell SafeBuilder; Rockwell Studio 5000 Logix	Windows workstation, project-file handlers (<code>.stu</code> / <code>.xef</code> for Schneider,	TIA Portal V21 media extracted (~686K hashes)

Class (role)	Products (cross-vendor)	Stack	Catalog depth
(L2/L3 jump host into L1.5)	Designer (Safety project); Siemens TIA Portal V21 + STEP7 Safety + Safety Matrix	.ap21 / .zap21 for Siemens, .ACD for Rockwell), vendor APIs (Openness)	— see siemens brief Group A ; other EWS stacks research-only
D. Safety Field Instrument (L0.5)	Smart transmitters and final-element devices addressed over HART/FOUNDATION Fieldbus/PROFIsafe by the logic solver in class A/B	Embedded MCU + fieldbus stack	not covered in source briefs — research gap

Class D (L0.5) is in scope for this layer but has no CVE data in the four source briefs cited above; all SIS-relevant data in those briefs concerns the logic solver and its EWS.

Group A — Triple/Quad-Redundant SIS Logic Solver (L1.5)

Direct attack surface (cross-vendor): TriStation protocol UDP/1502 (Schneider; no authentication, no firmware signing of downloaded function blocks; documented OOB memory-read primitive on Tricon MP), FSC-SafeNet UDP/51966 (Honeywell; unauthenticated diagnostic/control commands), SafeBuilder engineering link (proprietary TCP, Honeywell), serial diagnostic ports on both families. The mandatory physical key-switch in PROGRAM/RUN/REMOTE position is the single operational control between attacker and a TRITON-grade outcome — and TRITON 2017 succeeded specifically because the key was left in PROGRAM during normal operation.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2018-8872	7.5	Schneider	Triconex Tricon MP 3008	OOB memory read used by TRITON/TRISIS implant <code>trilog.exe</code> → <code>inject.bin</code> → <code>imain.bin</code>
TRITON/TRISIS framework (XENOTIME / TsNIIKhM / GRU GTsST)	n/a	Schneider	Triconex Tricon v10.0–10.4	Implant chain pushing tampered firmware to MP; key-switch in PROGRAM enabled the write — see Dragos XENOTIME profile
ICSA-18-107-02	n/a	Schneider	Triconex Tricon	CISA advisory tied to TRITON
CVE-2022-30313	high	Honeywell	Safety Manager FSC	Unauthenticated FSC-SafeNet protocol — diagnostic/control commands

CVE	CVSS	Vendor	Product	Vector
				accepted without authentication
CVE-2022-30314	high	Honeywell	Safety Manager FSC	Improper authentication / firmware update path on FSC
CVE-2022-30315	high	Honeywell	Safety Manager FSC	Insufficiently protected credentials / file-parsing memory corruption
ICSA-22-179-02	high	Honeywell	Safety Manager R145.1–R152.2	Claroty Team82 ICEFALL cluster on FSC

Honeywell brief notes: exact CVSS scores and one-line summaries for the CVE-2022-30313/14/15 trio differ slightly between NVD, Honeywell PSIRT, and Claroty's writeup — treat the table above as a pointer to the advisory cluster.

Top attack vector (MITRE ATT&CK ICS): [T0857 System Firmware](#) — TRITON wrote a new firmware image to the SIS controller. Chains with [T0858 Change Operating Mode](#) (flip out of RUN) and [T0839 Module Firmware](#) (push malicious logic block).

Group B — Integrated Safety PLC (L1.5, BPCS-converged chassis)

Direct attack surface (cross-vendor): CIP Safety over EtherNet/IP TCP/44818 + UDP/2222 on Rockwell GuardLogix 5580 / Compact GuardLogix 5380, sharing the chassis with standard ControlLogix/CompactLogix CPUs; PROFIsafe over PROFINET on Siemens S7-1500F/T-F, addressed via STEP7 Safety from TIA Portal. Both architectures inherit the *full* CIP / S7comm-Plus attack surface of their non-safety siblings — the safety task is a partitioned context on a shared CPU.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2021-22681	10.0	Rockwell	Logix family incl. GuardLogix 5580 / Compact GuardLogix 5380	Hardcoded cryptographic key in Studio 5000 → remote auth bypass to controller — ICSA-21-056-03
CVE-2022-1161	7.7	Rockwell	CompactLogix 5380/5480, ControlLogix 5580 (incl. Guard variants)	Stealthy logic injection — Studio 5000 view ≠ controller bytecode

CVE	CVSS	Vendor	Product	Vector
CVE-2024-6242	8.4	Rockwell	1756-EN4TR (carries safety chassis traffic)	CIP trusted-slot bypass — any chassis slot → controller
CVE-2023-2071	9.8	Rockwell	CompactLogix 5370 + EN2T-class comms	Crafted CIP packet → RCE on controller — ICSA-23-136-04
CVE-2022-38465	9.3	Siemens	S7-1200/1500 family (incl. S7-1500F)	Hardcoded global private key → bypass protected communication + native-code load
CVE-2020-15782	8.1	Siemens	S7-1500 (incl. F-variants)	Memory-protection bypass → native code (Claroty)

Top attack vector (MITRE ATT&CK ICS): [T0833 Modify Control Logic](#) of the safety task via the shared CPU's standard programming path — CVE-2022-1161's stealth-injection class is particularly dangerous on GuardLogix because the engineer's online view of the safety routine can diverge from running bytecode.

Group C — SIS Engineering Workstation (L2/L3 jump host into L1.5)

Direct attack surface (cross-vendor): Windows workstation hosting TriStation 1131 (Schneider), SafeBuilder (Honeywell), Studio 5000 Logix Designer with Safety add-on (Rockwell), or TIA Portal V21 + STEP7 Safety + Safety Matrix (Siemens). These workstations hold the project file, the controller credentials, and the keyswitch-state knowledge to push a tampered logic block into the SIS the moment the keyswitch permits it. The Openness API on TIA Portal is .NET-callable from PowerShell — code-exec on the EWS equals silent SIS reprogramming if the safety project is loaded.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2020-7559	7.8	Schneider	EcoStruxure Control Expert (sibling stack to TriStation 1131)	DLL hijack at engineering workstation startup
CVE-2021-22779	8.1	Schneider	Control Expert ↔ PLC (UMAS family)	UMAS session hijack from EWS
Claroty Team82 "Evil PLC" class	n/a	Schneider / Rockwell	Control Expert, Studio 5000	Weaponized PLC pushes payload to EWS on project

CVE	CVSS	Vendor	Product	Vector
				upload — team82 paper
CVE-2024-21915	9.8	Rockwell	FactoryTalk Service Platform (touches safety project auth)	Privilege escalation, affects Logix sessions — ICSA-24-018-01
CVE-2024-45824	9.8	Rockwell	FactoryTalk View ME / Studio 5000	Remote code injection via crafted project
CVE-2024-49775	7.8	Siemens	TIA Portal V21 (User Management Component)	Local privilege escalation — UMC version bundled with STEP7 Safety on DVD1
Siemens ProductCERT — TIA Portal Openness advisory class	7.x	Siemens	TIA Portal Openness API	Project-file deserialization → code exec on engineering host

Top attack vector (MITRE ATT&CK ICS): [T0873 Project File Infection](#) — engineer opens a tampered `.stu` / `.ap21` / `.ACD` carrying the safety routine, attacker pivots into the safety task. Chains directly with [T0843 Program Download](#) when the engineer subsequently downloads to the SIS.

Logging matrix (highest priority for this layer)

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	SIS key-switch state telemetry (Schneider Tricon + Honeywell FSC)	Key-switch state change to PROGRAM during unscheduled window	TRITON-shape precursor — the single operational guard	T0858 Change Operating Mode
2	TriStation protocol monitor	UDP/1502 traffic from any host other than the designated TS1131 EWS	TRITON-class recon/implant on Triconex	T0857 System Firmware
3	Honeywell Safety Manager FSC diagnostic log + FSC-SafeNet network sensor	UDP/51966 traffic from outside the designated SafeBuilder EWS subnet	Unauth FSC-SafeNet exploitation (CVE-2022-30313/14/15)	T0857 System Firmware

#	Source	Event	What it catches	MITRE ATT&CK ICS
4	Network IDS (Zeek/Suricata)	S7comm-Plus session to S7-1500F TCP/102 from outside engineering VLAN, or PROFIsafe writes from non-EWS source	Unauthorized safety-task programming	T0843 Program Download
5	Network IDS	CIP service codes 0x4B/0x4C/0x4D (program download) targeting a GuardLogix 5580/5380 safety slot from non-engineering subnet	Logic injection against integrated safety PLC	T0843 Program Download
6	Sysmon on SIS EWS	EventID 1 where ParentImage = <code>SafeBuilder.exe</code> / <code>TriStation*.exe</code> / <code>RSLogix5000.exe</code> / <code>Siemens.Automation.*</code> AND child is <code>cmd.exe</code> / <code>powershell.exe</code> / <code>rundll32.exe</code>	Evil-PLC project-file infection on safety EWS	T0853 Scripting
7	SIS controller audit (CIP 0xA0 on GuardLogix, S7-1500 CPU diagnostic buffer on S7-1500F, FSC system event)	<code>Firmware updated</code> / <code>Project downloaded</code> / <code>Operating mode change</code> event on a safety controller outside maintenance window	Direct SIS tamper	T0839 Module Firmware
8	Process historian / SOE recorder	SIS bypass-counter increment, voter desync between redundant MP modules, or trip signal suppression vs. expected interlock	Field-instrument tamper or trip suppression at L0.5	T0832 Manipulation of View

Secondary: Firewall egress — no SIS controller, SIS EWS, or safety chassis comms module should ever originate outbound to non-RFC1918. Vendor-native audit — turn on Honeywell FSC diagnostic log, Schneider TriStation event log, Rockwell FactoryTalk Diagnostics `Audit / Security / Configuration`, and Siemens S7-1500 CPU diagnostic buffer; forward all via syslog. Procedural — IEC 61511 functional-safety lifecycle review of any keyswitch-in-PROGRAM excursion; IEC 62443-3-3 SR-7 (resource availability) and SR-3 (system integrity) gates on safety-network segmentation.

Cross-layer pivots

1. **L3 EWS → L1.5 SIS via crafted firmware upload while keyswitch in PROGRAM (TRITON 4-stage model).** The canonical XENOTIME / TsNIIKhM attack on a Saudi petrochemical plant in 2017 staged from an L3 engineering workstation, used CVE-2018-8872's OOB read on the Tricon MP to map memory, then wrote `imain.bin` over TriStation UDP/1502 because the keyswitch was left in PROGRAM. The attack ultimately *failed* because the modified safety logic

itself triggered a plant shutdown — the FAILSAFE worked as designed. The same shape applies to Honeywell FSC via CVE-2022-30313 (unauthenticated SafeNet) and to GuardLogix/S7-1500F via the EWS project-file infection path (CVE-2024-21915 / CVE-2024-49775).

2. **L1 BPCS → L1.5 SIS via shared safety-network segment (if not properly air-gapped).**

GuardLogix 5580 and S7-1500F by design share a chassis or rack with standard control CPUs, so a compromise of the BPCS portion (e.g., via CVE-2024-6242 CIP trusted-slot bypass on 1756-EN4TR, or CVE-2022-38465 S7 global-key on a sibling S7-1500) can reach the safety task across the chassis backplane unless safety segmentation is enforced in configuration. This is the integrated-safety-PLC weakness that the air-gapped Triconex architecture does not have.

3. **SIS bypass enables follow-on destructive L1/L0 attack that safety would otherwise halt.**

Once the safety logic is silenced (CVE-2022-1161 stealth-injection class on GuardLogix, or the TRITON `imain.bin` implant on Tricon), the attacker is free to drive an L1 BPCS into a destructive state — pressure excursion, runaway exotherm, mechanical overspeed — without the trip the safety system was specified to enforce. The L1 attack vectors (CIP writes, S7comm-Plus program download, UMAS function 0x5A) become physically consequential only once Group A or Group B is defeated.

4. **Field-instrument tamper (L0.5) → suppressed trip signals.** A compromised HART/PROFIsafe transmitter at L0.5 (research gap in source briefs — Class D has no CVE coverage in this aggregation) can feed a "process is safe" reading to a fully-uncompromised L1.5 logic solver, defeating the trip without ever touching the SIS controller. Detection requires correlation between transmitter readings and independent process-historian / SOE recorder data.

Sources

- [CISA ICSA-18-107-02 — Triconex / TRITON](#)
- [CISA ICSA-22-179-02 — Honeywell Safety Manager \(FSC\) / Claroty ICEFALL](#)
- [CISA ICSA-21-056-03 — Logix Controllers CVE-2021-22681](#)
- [CISA ICSA-23-136-04 — CompactLogix 5370 CVE-2023-2071](#)
- [CISA ICSA-24-018-01 — FactoryTalk Service Platform CVE-2024-21915](#)
- [CISA AA24-038A — Volt Typhoon US Critical Infrastructure \(ControlLogix recon\)](#)
- [Schneider Electric PSIRT / Cybersecurity Support Portal](#)
- [Honeywell PSIRT / Security Notifications](#)
- [Rockwell Automation Trust Center — Security Advisories](#)
- [Siemens ProductCERT advisory index](#)
- [Dragos — TRISIS / TRITON malware analysis](#)
- [Dragos — XENOTIME threat profile](#)
- [Mandiant/FireEye TRITON technical analysis](#)
- [Claroty Team82 — Evil PLC Attack \(Schneider + Rockwell\)](#)

- [Claroty Team82 — Stealthy Rockwell PLC Hack \(CVE-2022-1161\)](#)
- [Claroty Team82 — Bypassing the Trusted Slot on 1756-EN4TR \(CVE-2024-6242\)](#)
- [Claroty Team82 — Race to Native Code Execution on S7-1500](#)
- [Forescout — OT:ICEFALL companion research](#)
- [MITRE ATT&CK for ICS — T0857 System Firmware](#)
- [MITRE ATT&CK for ICS — T0858 Change Operating Mode](#)
- [MITRE ATT&CK for ICS — T0839 Module Firmware](#)
- [MITRE ATT&CK for ICS — T0843 Program Download](#)
- [MITRE ATT&CK for ICS — T0833 Modify Control Logic](#)
- [MITRE ATT&CK for ICS — T0873 Project File Infection](#)
- [IEC 61511 — Functional safety: Safety instrumented systems for the process industry sector](#)
- [IEC 62443-3-3 — System security requirements and security levels \(SR-3 system integrity, SR-7 resource availability\)](#)
- [Purdue Enterprise Reference Architecture \(PERA\) — ISA-95 / ISA-99 layered model](#)
- [eaton brief](#) — structural template
- [schneider brief Group C](#) — Triconex Tricon/Trident/Tri-GP, TRITON case study, CVE-2018-8872
- [honeywell brief Group E](#) — Safety Manager FSC, CVE-2022-30313/14/15, ICSA-22-179-02
- [siemens brief Group A/D](#) — TIA Portal V21 + STEP7 Safety, S7-1500F/T-F, CVE-2022-38465
- [rockwell brief Group A/B](#) — GuardLogix 5580, Compact GuardLogix 5380, CVE-2022-1161